

ECサイト インシデント対応BCPマニュアル

第2版 2026年4月1日 発行

株式会社ブリックスマート インフラ管理部

第1章 目的と適用範囲

本マニュアルは、ECサイト「ブリックスマート」においてセキュリティインシデントやシステム障害が発生した際の対応手順を定めるものである。全システム管理者およびEC運用担当者に適用される。

第2章 インシデントレベルの定義

レベル	条件	対応目標
Level 1（注意）	不審アクセスが通常の2倍以上	30分以内に状況把握
Level 2（警戒）	不審アクセスが通常の3倍以上、または特定IP帯からの集中アクセス	15分以内に対策開始
Level 3（緊急）	サービスダウンの兆候、または大規模情報漏洩の疑い	即時対応（5分以内）

第3章 インシデント対応フロー

3.1 検知

- ・セキュリティ監視ダッシュボードのアラートにより検知
- ・自動通知: Slack #security-alerts に自動投稿

3.2 初動対応（最初の30分）

1. インシデントレベルの判定
2. 対応チームの招集（第6章のエスカレーション基準に基づく）
3. 影響範囲の初期評価
4. 一次対策の実施（IPブロック等）

3.3 封じ込め

攻撃種別	封じ込め手段	実施者
ブルートフォース	対象IPのWAFブロック + 対象アカウントの一時ロック	インフラチーム
BOTアクセス	User-Agentベースのフィルタリング + レートリミット強化	インフラチーム
不正購入	対象アカウントの凍結 + 決済の一時停止	セキュリティチーム + 決済チーム
DDoS	CDNのDDoS防御機能を有効化 + ISPへの連絡	インフラチーム

3.4 復旧

1. 攻撃トラフィックの停止を確認
2. 影響を受けたアカウント・データの確認
3. 必要に応じてパスワードリセットの強制
4. サービスの段階的復旧

3.5 事後対応

1. インシデントレポートの作成（48時間以内）
 2. 根本原因分析（RCA）の実施
 3. 再発防止策の策定と実装
 4. 影響を受けた顧客への通知（顧客対応ポリシーに基づく）
-

第4章 BOT攻撃対応手順

4.1 BOTの検知指標

以下のパターンが検出された場合、BOT攻撃と判定する。

- 同一IPまたは同一サブネットからの大量アクセス
- 同一アカウントから短時間での大量カート操作（add_to_cart → abandon の繰り返し）
- User-Agentが一般的なブラウザと異なるパターン
- 購入なしのカート占有（高額商品を在庫確保目的でカートに入れ続ける行為）

4.2 対応手順

1. **検知**: セキュリティダッシュボードまたはアラートで検知
2. **確認**: 対象ユーザーのリスクスコアと行動履歴を確認
3. **遮断**: 対象IP帯のブロック（WAF設定変更）
4. **アカウント対応**: 対象アカウントを凍結（アカウント管理ガイドラインに基づく）
5. **在庫復元**: BOTにより占有されていたカートの在庫を解放
6. **正規顧客対応**: BOTにより購入できなかった正規顧客を特定し、救済施策を実施（顧客対応ポリシー第5章参照）

4.3 転売BOTへの特別対応

- 限定商品の発売時にBOT購入が検知された場合、注文を一括キャンセル可能
- キャンセルした在庫は「購入できなかった正規の優良顧客」への先行販売に回す
- マーケティング施策テンプレート集のテンプレートB-3（シークレット先行販売）を使用

第5章 サイト停止判断基準

5.1 基本原則

サイトの全面停止（メンテナンスモード移行）は**最終手段**として位置づける。

5.2 全面停止の基準

以下の**いずれか**に該当する場合は、即座に全面停止を実施する。

1. **個人情報漏洩の確認または高い蓋然性がある場合**

2. データベースの整合性が損なわれている場合

3. 決済システムに異常が発生している場合

5.3 部分制限の基準

以下の場合、全面停止ではなく部分的な制限で対応する。

- ・ 攻撃元が特定可能な場合 → 対象IPのみブロック
- ・ 特定の機能のみに影響がある場合 → 該当機能のみ一時停止
- ・ 負荷増大だがサービス維持可能な場合 → レートリミット強化

第6章 エスカレーション基準

状況	連絡先	手段
Level 1	インフラチームリーダー	Slack #security-alerts
Level 2	インフラチームリーダー + セキュリティマネージャー	Slack + 電話
Level 3	上記 + CTO + 法務部	電話（即時）
個人情報漏洩の疑い	上記 + DPO（データ保護責任者） + 代表取締役	電話（即時）

緊急連絡網

役職	氏名	電話番号
インフラチームリーダー	山田 太郎	090-XXXX-1111
セキュリティマネージャー	佐藤 花子	090-XXXX-2222
CTO	鈴木 一郎	090-XXXX-3333
DPO	高橋 次郎	090-XXXX-4444
EC事業部長	田中 太郎	090-XXXX-5555

第7章 インシデントレポートテンプレート

項目	記入内容
インシデントID	INC-yyyy-mm-dd-001
発生日時	yyyy-mm-dd HH:MM
検知方法	ダッシュボードアラート / 手動検知 / 顧客報告
インシデントレベル	Level 1 / 2 / 3
攻撃種別	ブルートフォース / BOT / 不正購入 / DDoS / その他
影響範囲	影響を受けたアカウント数、データの種類
初動対応	実施した一次対策の内容
封じ込め	実施した封じ込め措置
復旧	復旧手順と所要時間
根本原因	RCA結果
再発防止策	実施予定の対策
対応完了日時	yyyy-mm-dd HH:MM